

DECENTRALIZED BLOCKCHAIN SYSTEM

An in-depth analysis of Blockchain Vulnerabilities and Best Practice

1. Introduction to Decentralized System

Decentralized system is a digital technology that operates without a single person controlling it. Instead, its control is divided among multiple participants, also called nodes present in the network which makes verifying the data easier. Even if some nodes fail, the network still remains functional.

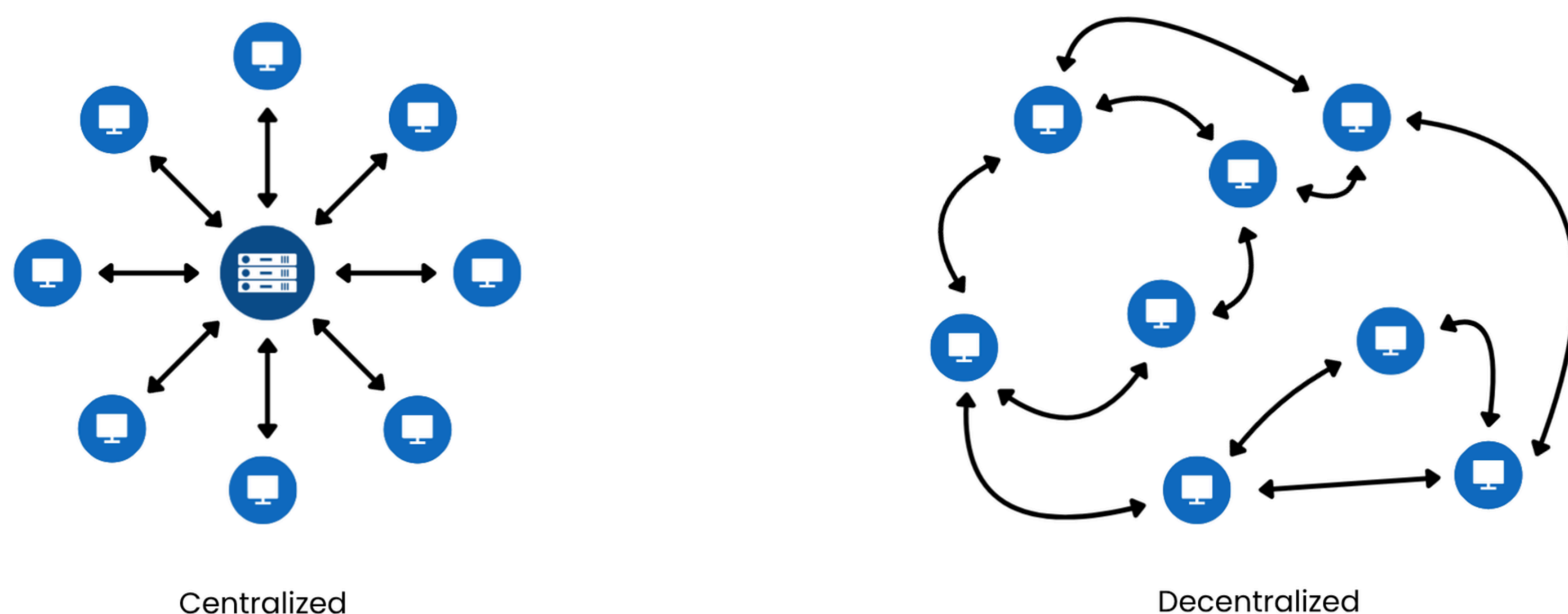


Figure 1 : The difference between centralized and decentralized systems

OPERATION OF BLOCKCHAIN SYSTEM

The process begins with user initiating a transaction. This transaction is broadcast to all the nodes present in the network. Each node receives the transaction verifies it. The node check if the user has sufficient funds, digital signature is present and the transaction follows all the network rules. Multiple valid transactions are grouped together into a block which is added to the blockchain.

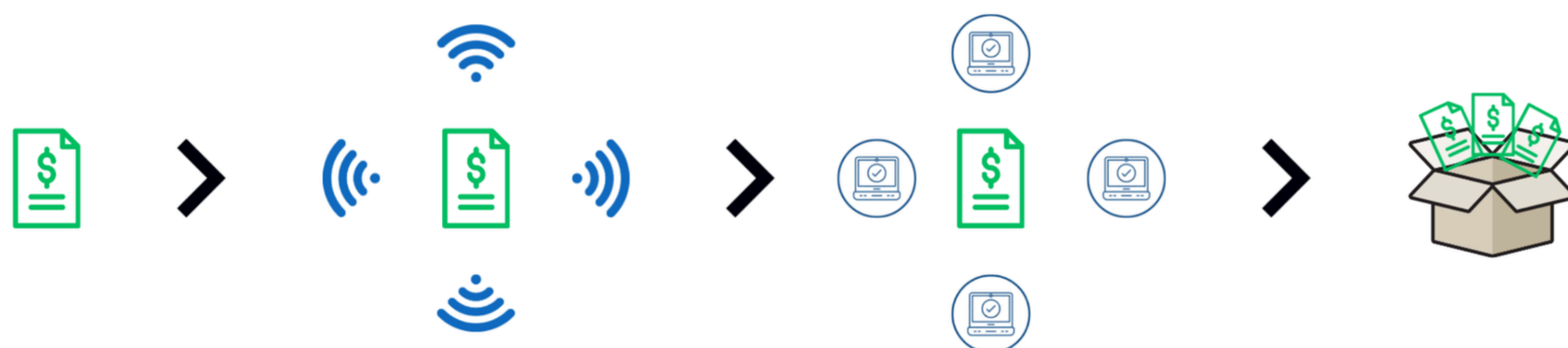


Figure 2 : The process of formation of block in the blockchain

2. Smart Contract Vulnerabilities

Reentrancy Attack

A reentrancy attack occurs when a smart contract sends funds to an external contract before updating its internal state. This allows multiple withdrawals before balance is updated, causing funds to drain completely. The famous **DAO Hack** exploited this vulnerability

Flash Loan Attacks

Flash loans allow users to borrow large amounts of cryptocurrency without collateral, provided repayment occurs within the same transaction. Manipulators borrow large funds, manipulates token prices and repays the loan, keeping the extra profit within themselves

3. Cybersecurity Threats in DeFi Systems

51 % ATTACK

The 51% attack is a vulnerability in a blockchain network where a single entity gains control of more than 50% of the network's decision-making power. This allows attackers to send cryptocurrency to a merchant and one transaction and then send the same cryptocurrency to another merchant because they control majority of the hash power. They can also block new transactions from being verified and prevent other miners from claiming their reward.



Figure 3 : Demonstration of 51% Attack

WALLET THEFT

Wallet theft occurs when an attacker gains unauthorized access to a user's cryptocurrency wallet and transfer the assets to their own wallet. Since blockchain transactions are irreversible, stolen funds are nearly impossible to recover.

PHISHING ATTACK

Attackers create fake website, emails, application or malicious software that imitate legitimate cryptocurrency services but in reality, they target user's cryptocurrency wallets.

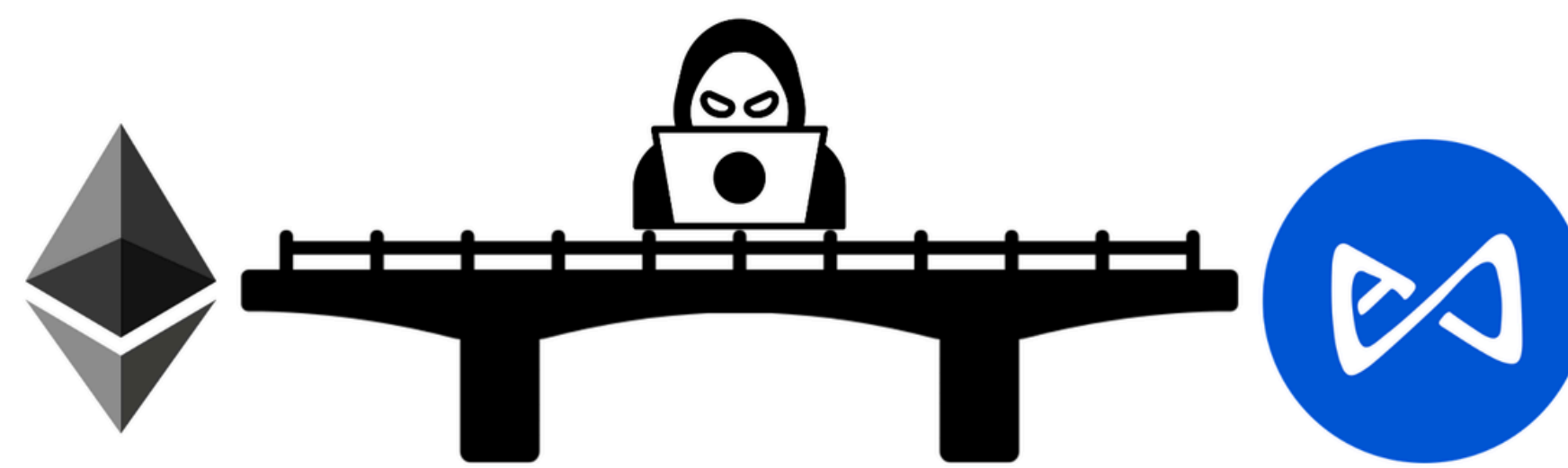
4. CROSS-CHAIN BRIDGE VULNERABILITIES

WEAK VERIFICATION

Many bridges rely on small set of validators or multisignature wallets to approve transactions. If enough signing keys are stolen then attackers are able to authorize fraudulent withdrawals. Attackers can also find a bug in poorly written smart contract verification logics and bypass the validation checks.

RONIN BRIDGE HACK

The Ronin Bridge Hack was a major cryptocurrency theft on 23 March, 2022. The bridge connected Axie Infinity to Ethereum. Ronin used nine validator nodes which requires five signature for any deposit / withdrawal. The attackers obtained control over five of these validators. With majority control, they authorize two fake withdrawals that drained a large portion of the bridge comprising of 173,600 ETH and 25.5M USDC.



Ronin Bridge Hack

Figure 4 : The Ronin Bridge Hack of 22 March, 2022

5. BEST PRACTICES FOR USER SECURITY IN BLOCKCHAIN

STRENGTHEN VALIDATOR AND PRIVATE KEY

One of the major reason of these attacks is the attackers gaining access to validator credentials. Strengthening and increasing the number of validators prevents unauthorized transaction approvals and makes it much harder for attackers to gain majority control.

COMPREHENSIVE SMART CONTRACT AUDITS

Before deployment, bridge smart contracts should be tested extensively to avoid any coding errors or logic flaws. Bridges should be monitored in real time and be prepared for potential attacks. One way to achieving this is encouraging ethical hackers to identify vulnerabilities and hidden security flaws by offering rewards and conducting security testing programs.

6. ZERO-KNOWLEDGE PROOF BASED DECENTRALIZED IDENTITY

Current Identity Verification works by a person uploading his/her personal information on a company's website and it's the job of the company to protect this information. This creates several cybersecurity risks including data breach, identity theft etc. This is where DID comes in play. Decentralized Identity (DID) allows users to hold their credentials in a digital wallet. The credentials are verified cryptographically. This acts as a replacement for traditional username-password systems. Zero-Knowledge Proof (ZKP) is a cryptographic technique that allows someone to prove a statement is true without disclosing sensitive information. Currently researchers are working in the development of this framework.

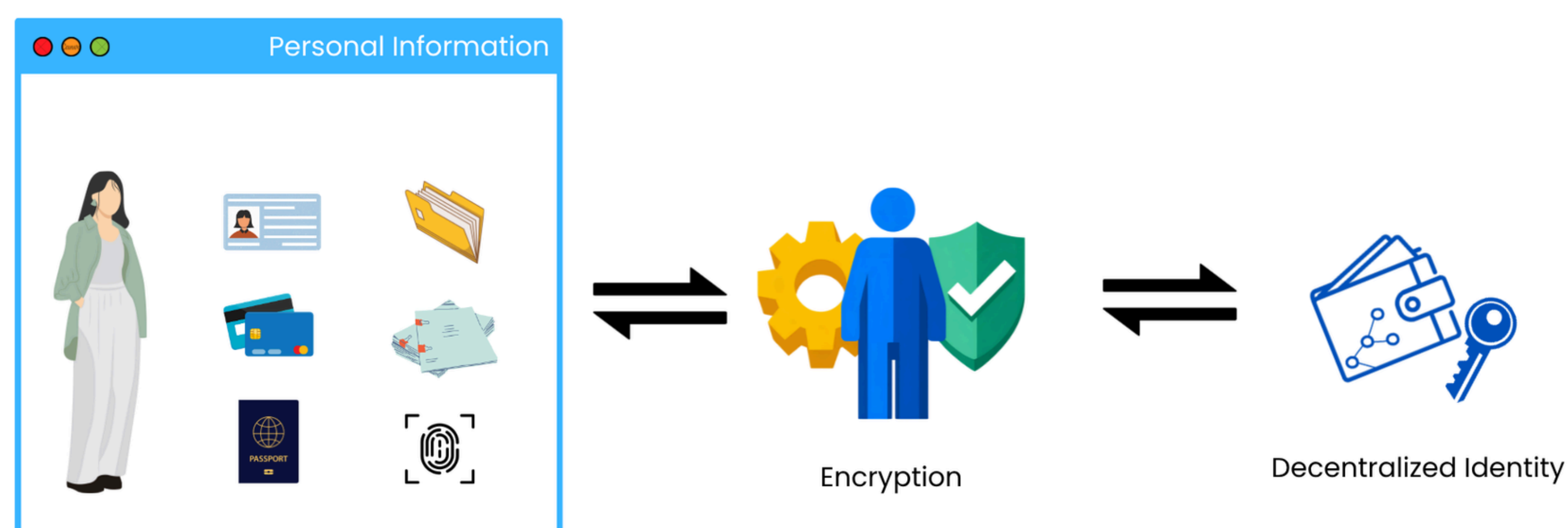


Figure 5 : The encryption of sensitive information into a encrypted digital identity